Vulnerability Report: SSRF pada WAF yang Salah Konfigurasi Menyebabkan Kebocoran 106 Juta Data Nasabah Capital One (2019)

Nama: Mochamad Aldi Ardiansyah | NIM: 1224020 | Mata Kuliah: Implementasi Pengujian Perangkat Lunak | Tugas Terstruktur Minggu ke-9

1. Kategori OWASP

A10 — Server-Side Request Forgery (SSRF) (OWASP Top 10 – 2021)

2. Deskripsi Kerentanan

Celah berada pada *web application firewall* (WAF) ModSecurity yang berjalan di server AWS EC2 milik Capital One. Akibat konfigurasi yang salah, WAF dapat dipaksa mengirim permintaan HTTP ke alamat tujuan pilihan penyerang tanpa validasi. Penyerang mengarahkan permintaan itu ke layanan metadata instance AWS (IMDS, alamat 169.254.169.254) yang membalas dengan kredensial sementara milik IAM role server. Dampaknya diperbesar oleh dua kelemahan lain: IAM role milik WAF memiliki izin terlalu luas ke bucket S3 (melanggar *least privilege*), dan IMDS versi 1 menjawab tanpa autentikasi tambahan.

3. Studi Kasus

Organisasi: Capital One (AS/Kanada). **Tahun:** serangan 22–23 Maret 2019, diumumkan 29 Juli 2019. **Pelaku:** Paige A. Thompson, mantan engineer AWS, dinyatakan bersalah pada Juni 2022. **Sumber:** siaran pers U.S. DOJ, pengumuman resmi Capital One, dan analisis teknis publik (lihat Referensi). Insiden ini tidak memiliki nomor CVE karena akar masalahnya adalah kesalahan konfigurasi dan desain akses, bukan bug pada satu produk.

4. Kronologi Kerentanan Dimanfaatkan

1. Penyerang menemukan WAF yang salah konfigurasi sehingga dapat meneruskan permintaan ke tujuan sembarang.
2. Penyerang membuat WAF mengakses layanan metadata EC2 dan membaca nama serta kredensial IAM role server.
3. IMDSv1 membalas tanpa autentikasi tambahan dengan access key, secret key, dan session token sementara milik role WAF.
4. Dari luar jaringan, penyerang memakai kredensial itu lewat AWS CLI (identitas disamarkan dengan Tor dan VPN) untuk mendaftar bucket S3 dan menyalin isinya, sekitar 30 GB dari lebih dari 700 bucket.
5. Penyerang memamerkan data di GitHub dan media sosial. Capital One mengetahui insiden pada pertengahan Juli 2019 (sekitar empat bulan kemudian) dan penyerang ditangkap pada 29 Juli 2019.

5. Dampak

- **Data terdampak:** data aplikasi kartu kredit 2005–2019 sekitar 100 juta orang di AS dan 6 juta di Kanada (nama, alamat, tanggal lahir, penghasilan, skor kredit), termasuk sekitar 140.000 nomor jaminan sosial (SSN), sekitar 1 juta nomor asuransi sosial Kanada (SIN), dan sekitar 80.000 nomor rekening bank.
- **Pihak dirugikan:** nasabah dan pelamar kartu kredit (risiko pencurian identitas dan penipuan finansial); Capital One (denda USD 80 juta dari OCC pada 2020, penyelesaian gugatan kelompok USD 190 juta, kerusakan reputasi).
- **Pilar CIA:** *Confidentiality* rusak berat karena data pribadi dan finansial dibaca dan disalin pihak tidak berwenang. *Integrity* tidak ada bukti perubahan data. *Availability* layanan tidak dilaporkan terganggu.

6. Estimasi Severity

Skor CVSS v3.1 perkiraan: 8,6 (High), vektor AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N. Ini estimasi penulis, bukan skor resmi.

- AV:N, AC:L, PR:N, UI:N: dieksploitasi lewat jaringan, mudah, tanpa akun, tanpa interaksi pengguna.
- S:C (*scope changed*): celah di WAF memberi akses ke sumber daya lain di luar komponen yang rentan, yaitu bucket S3.
- C:H: data pribadi dan finansial jutaan orang terbuka. I:N dan A:N karena tidak ada bukti modifikasi data atau gangguan layanan.
- Skor mendekati batas Critical (9,0). Jika role memiliki izin tulis (I:L), skor naik menjadi 9,3 (Critical).

7. Rekomendasi Mitigasi

1. **Wajibkan IMDSv2** (permintaan berbasis token sesi) dan batasi akses metadata dari aplikasi web, sehingga SSRF sederhana tidak dapat mengambil kredensial. AWS merilis IMDSv2 setelah insiden ini.
2. **Terapkan least privilege pada IAM role.** Role WAF hanya boleh mengakses sumber daya yang benar-benar dibutuhkan, bukan seluruh bucket S3 berisi data nasabah.
3. **Validasi tujuan permintaan di server:** gunakan allowlist domain/IP, blokir alamat *link-local* (169.254.0.0/16), localhost, dan rentang IP privat, serta terapkan egress *deny-by-default*.
4. **Monitoring dan enkripsi:** aktifkan CloudTrail, GuardDuty, dan Macie untuk mendeteksi pengunduhan S3 yang tidak wajar, serta enkripsi atau tokenisasi data sensitif seperti SSN.

8. Referensi

1. OWASP Foundation. (2021). A10:2021 – Server-Side Request Forgery. https://owasp.org/Top10/A10_2021-Server-Side_Request_Forgery_%28SSRF%29/

2. U.S. Department of Justice (2019). Seattle Tech Worker Arrested for Data Theft Involving Large Financial Services Company. https://www.justice.gov/usao-wdwa/pr/seattle-tech-worker-arrested-data-theft-involving-large-financial-services-company
3. Capital One (2019). Information on the Capital One Cyber Incident. https://www.capitalone.com/digital/facts2019/
4. GovInfoSecurity (2019). Capital One's Breach May Be a Server Side Request Forgery. https://www.govinfosecurity.com/capital-ones-breach-may-be-server-side-request-forgery-a-12871
5. Wiz Threats. Capital One Breach. https://threats.wiz.io/all-incidents/capital-one-breach
6. FIRST. CVSS v3.1 Calculator. https://www.first.org/cvss/calculator/3.1